ET AI HACKATHON · AGENTIC EDITION · PROBLEM 2



# PromptShield

A prompt-injection firewall for AI agents.

It checks untrusted text and files before the model sees them,
neutralises the hidden instruction, and still lets the ordinary text through.

GitHub

**https://github.com/Sohamsurve/PromptShield.git**

**Submitted by: Soham Y. Surve**

# The problem

Agents treat retrieved content as instructions.

01

## Hidden instruction

A line in an email, PDF, or web page can override the task the user actually asked for.

02

## Side effect

The same line can ask the agent to reveal a secret or call a tool such as send-email.

03

## Wrong tool

A toxicity filter does not catch this. Tool permissions still matter, and this firewall does not replace them.

# Key features

### Scan first

Every prompt and file is checked before it reaches the agent.

### Redact the span

Only the offending sentence is removed. The rest of the document stays.

### Safe alternative

On block or quarantine, the caller gets the benign remainder, not the attack.

### Tool firewall

A tainted send-email is denied even when text scanning is switched off.

### Five answers

- **Allowed**
- **Sanitised**
- **Quarantined**
- **Blocked**
- **Needs review**

# Architecture

Each step is an action, a decision, and the part of the demo that shows it.

| | | |
|---|---|---|
| 1 | **Extract** | Hidden text is surfaced. No model. The specimen email marks only the hidden sentence. |
| 2 | **Detect** | Signatures, then a small classifier. The judge may add a finding and never decides alone. X-ray shows the reason. |
| 3 | **Decide** | Fusion picks Allowed, Sanitised, Quarantined, Blocked, or Needs review. A quoted attack stays Allowed. |
| 4 | **Neutralise** | Only the bad span is removed. The protected Arena lane keeps the ordinary mail. |
| 5 | **Guard** | The tool firewall denies a tainted send-email even when text scanning is off. |

# AI capabilities

What actually decides, and what the demo measured.

01

## Signatures

Deterministic rules run first. They name the span and the reason code.

02

## Classifier

A small local model runs next. It is not a large language model.

03

## Judge

An optional language model may add a finding in the gray zone. It cannot block a document by itself.

04

## Demo agent

The Arena agent is scripted, so the result repeats. A live model agent was not the measured subject.

# Live cases

The working demo. Each case is a claim the prototype is allowed to show.

01

## Arena

The same email, firewall off and on. The unprotected agent follows the hidden line.

02

## X-ray

Revealed view, a reason code, and a safe alternative that does not keep the canary.

03

## Clean pass

A security article that only quotes an attack stays Allowed.

04

## Tool firewall

Text scanning off. A tainted send-email is still denied.

# Measured on the frozen golden suite

Judge off. Shipped policy. 11 October 2026. Not tuned on these rows.

| 0.61 | 0.48 | 0 / 500 | 26 ms |
|---|---|---|---|
| **Acted recall** | **Correct type** | **False positives** | **Latency p95** |
| 900 attacks | 900 attacks | Ordinary documents | Without the judge |

### Caught in full

Indirect injection, 100 of 100 on this suite.

### Still weak

Multi-step jailbreaks: acted 0.35, correct type 0.00.

### Other pack

Imported sentences: acted 0.18, false positives 0 of 32.

Security: uploads are never executed. Demo tools are mocks. The judge never blocks a document by itself.

Full table: docs/CLAIMS.md · Report: eval/golden/reports/20261011T090211Z

# What we declare

## F1 / D1

Provisional. Nine attack types and the listed formats are in the product. An independent sealed run has not been scored.

## Not claimed

F3 and D3. Known-pattern recall of 0.95. Held-out recall of 0.85. A length-matched false-positive rate at or under 2 percent.

Exact white-on-white text is not in the pixels, so OCR cannot read it.

The Arena agent is scripted. A live language-model agent was not the measured subject.

The judge can add a finding. It cannot block a document by itself.

# Business impact

What changes on the path in front of the model. No market numbers.

01

## The task stays the user's

The hidden forward does not run. The agent keeps the job it was given.

02

## The document stays usable

On the frozen suite, 500 ordinary documents stayed allowed.

03

## Side effects fail closed

A tainted send-email is denied even when text scanning is off.

04

## Any agent, one check

The same API sits in front of the model's own client. PromptShield does not replace the model.

# PromptShield

Check the content. Remove the attack. Keep the document.

| API | Console | Detection | Demo store |
| --- | --- | --- | --- |
| Python and FastAPI | Next.js | Signatures, then a small classifier | SQLite |

GitHub

**https://github.com/Sohamsurve/PromptShield.git**

**Submitted by: Soham Y. Surve**